

PromptHalo — SOC 2 Control and Policy Mapping

Controls to documents, documents to controls, ownership, gaps in both directions, and a visual map. Tables group two levels deep, collapse, sort and search; switch between full and compact rows. Click any summary tile to jump straight to what it counts. Source: Control Plan v2.1 and the policy library of 23 July 2026.

160
CONTROLS

26
DOCUMENTS ›

118
FULLY COVERED ›

27
PARTIAL ›

15
NOT COVERED ›

9
UNTRACEABLE ›

55
GAPS TO CLOSE ›

All 160 controls with the document that should own each and the role accountable. Grouped criterion group → criterion, so every subcontrol collapses into its control. A document in red does not exist in the library.

CONTROL ▲	CRITERION ▲	CONTROL ACTIVITY ▲	OWNING DOCUMENT AND SECTION ▲	OWNER ▲	FREQUENCY ▲	COVERED ▲	SCORE ▲
▼ CC1 · Control Environment 7 covered · 21 to fix							
▼ CC1.1 0 covered · 6 to fix							
▶ CC1.1-01	CC1.1	Code of Conduct (POL-COC-001) approved by the Steering Committee and published to all personnel.	POL-COC-001 + POL-ISP-001 POL-COC-001 (authorised by POL-ISP-001 §13 Annex A)	CEO	Annual	Partial	0
▶ CC1.1-02	CC1.1	Every employee and contractor accepts the Code of Conduct at onboarding, on material revision, and annually.	POL-COC-001 + POL-HRS-001 POL-COC-001 §17 + POL-HRS-001	Security Officer	On hire + annual	Partial	0
▶ CC1.1-03	CC1.1	Conflict of interest declaration completed annually and whenever a new client engagement is accepted.	POL-COC-001 + POL-COI-001 POL-COC-001 §7 (no separate POL-COI-001 exists in the library)	CEO	Annual + per engagement	No	0
▶ CC1.1-04	CC1.1	Ethics reporting channel that bypasses the Security Officer, with anti-retaliation stated.	POL-COC-001 + POL-ISP-001 POL-COC-001 §16 + POL-ISP-001 §7	CEO	Continuous	No	0
▶ CC1.1-05	CC1.1	Conduct deviations are documented with the finding, the decision and the rationale.	POL-COC-001 + POL-HRS-001 POL-COC-001 §18 + POL-HRS-001	CEO	As they occur	Partial	0

CONTROL ▲	CRITERION ▲	CONTROL ACTIVITY ▲	OWNING DOCUMENT AND SECTION ▲	OWNER ▲	FREQUENCY ▲	COVERED ▲	SCORE ▲
▶ CC1.1-06	CC1.1	Background screening is completed and recorded for every new starter before access is granted, showing the tier applied, the date completed, the outcome and who authorised access afterwards.	POL-HRS-001 + STD-SCR-001 POL-HRS-001 + STD-SCR-001 (to create)	CEO	Per Hire	Yes	1
▼ CC1.2 1 covered · 5 to fix							
▶ CC1.2-01	CC1.2	Governance body defined: the Steering Committee comprises the CEO, satisfied by a dated written record.	POL-ISP-001 POL-ISP-001 §4 (Terminology)	Security Officer	Annual	Yes	2
▶ CC1.2-02	CC1.2	Every approval, risk acceptance and exception is recorded with the date and the person deciding.	POL-ISP-001 POL-ISP-001 → Governance Log	CEO	Continuous	Partial	1
▶ CC1.2-03	CC1.2	The absence of oversight independent of security operations is recorded as a risk with an annual review date.	POL-RSK-001 POL-RSK-001 → risk register	Security Officer	Annual	Partial	1
▶ CC1.2-04	CC1.2	CEO reviews and signs the Security Officer's control effectiveness assessment.	POL-ISP-001 + FRM-CE-001 POL-ISP-001 §8 → FRM-CE-001	CEO	Annual	Partial	1
▶ CC1.2-05	CC1.2	RECOMMENDED — an advisor outside the management reporting line reviews the annual assessment and signs a short oversight memo.	POL-ISP-001 + FRM-CE-001 POL-ISP-001 → FRM-CE-001 Annex A	CEO	Annual	No	N/A
▶ CC1.2-06	CC1.2	Committee composition is reviewed as the Company grows and additional members are appointed when available.	POL-ISP-001 POL-ISP-001	CEO	Annual	No	0
▼ CC1.3 2 covered · 3 to fix							
▶ CC1.3-01	CC1.3	Current org chart showing reporting lines, including contractors and the fractional CISO.	POL-ISP-001 POL-ISP-001 → org chart in governance repo	CEO	Annual + on hire	No	0
▶ CC1.3-02	CC1.3	Each role description states its security responsibilities.	POL-HRS-001 POL-HRS-001 → role descriptions	CEO	Annual	Yes	1

CONTROL ▲	CRITERION ▲	CONTROL ACTIVITY ▲	OWNING DOCUMENT AND SECTION ▲	OWNER ▲	FREQUENCY ▲	COVERED ▲	SCORE ▲
▶ CC1.3-03	CC1.3	The Accountable Party is named: the CEO, or the Security Officer in their absence.	POL-ISP-001 POL-ISP-001	Security Officer	Annual	Yes	1
▶ CC1.3-04	CC1.3	Delegated duties are documented with their scope and duration.	POL-ISP-001 POL-ISP-001 → Governance Log	CEO	As they occur	No	0
▶ CC1.3-05	CC1.3	Segregation of duties assessed; where not practicable, compensating controls are documented.	POL-ISP-001 + FRM-CE-001 POL-ISP-001 §7 → FRM-CE-001 §7	Security Officer	Annual	No	0
▼ CC1.4 2 covered · 4 to fix							
▶ CC1.4-01	CC1.4	Competency requirements, including required skills and certifications, defined per role.	POL-HRS-001 POL-HRS-001 → role descriptions	CEO	Annual	Partial	0
▶ CC1.4-02	CC1.4	Background screening completed before access to production systems or customer data is granted.	POL-AC-001 + STD-SCR-001 POL-AC-001 + STD-SCR-001 (to create)	Security Officer	Per hire	Yes	1
▶ CC1.4-03	CC1.4	Onboarding checklist completed for every joiner: policies, training, screening, access, equipment.	POL-HRS-001 POL-HRS-001	Security Officer	Per hire	Yes	1
▶ CC1.4-04	CC1.4	Security awareness training completed at onboarding and at least annually.	POL-SAT-001 POL-SAT-001	Security Officer	On hire + annual	Yes	1
▶ CC1.4-05	CC1.4	Remote working requirements — device standard, network, physical handling of screens and printouts — acknowledged.	POL-COC-001 + STD-EPT-001 POL-COC-001 §12 + STD-EPT-001	Security Officer	On hire + annual	Partial	0
▶ CC1.4-06	CC1.4	Contractors meet the same screening, training and acknowledgment requirements as employees.	POL-HRS-001 + POL-VM-001 POL-HRS-001 + POL-VM-001	Security Officer	Per engagement	No	0
▼ CC1.5 2 covered · 3 to fix							
▶ CC1.5-01	CC1.5	Security responsibilities are communicated and accepted as a condition of employment or engagement.	POL-COC-001 + POL-HRS-001 POL-COC-001 §17 + POL-HRS-001	Security Officer	On hire + annual	Yes	1

CONTROL ▲	CRITERION ▲	CONTROL ACTIVITY ▲	OWNING DOCUMENT AND SECTION ▲	OWNER ▲	FREQUENCY ▲	COVERED ▲	SCORE ▲
▶ CC1.5-02	CC1.5	Performance review includes control and security responsibilities.	POL-HRS-001 POL-HRS-001	CEO	Annual	No	0
▶ CC1.5-03	CC1.5	Every control has a named owner and a defined operating frequency.	POL-ISP-001 POL-ISP-001 §8 → control matrix	Security Officer	Quarterly	Partial	1
▶ CC1.5-04	CC1.5	Controls that do not operate on schedule become deficiencies, are tracked in the plan of action and escalated when overdue.	POL-ISP-001 + POL-RSK-001 POL-ISP-001 §8 + POL-RSK-001 §9	Security Officer	Quarterly	Yes	1
▶ CC1.5-05	CC1.5	Security Officer documents the finding and recommends; CEO determines, documents and consistently applies the outcome.	POL-COC-001 + POL-HRS-001 POL-COC-001 §18 + POL-HRS-001	CEO	As they occur	Partial	1
▼ CC2 · Communication and Information 9 covered · 8 to fix							
▼ CC2.1 5 covered · 0 to fix							
▶ CC2.1-01	CC2.1	A System Security Plan describes the system boundary, environments of operation and implemented controls, and is reviewed at least annually.	POL-ISP-001 POL-ISP-001 §8	Security Officer	Annual	Yes	1
▶ CC2.1-02	CC2.1	An asset inventory covers systems, SaaS, cloud resources and repositories, each with a named owner and its data classification.	POL-AM-001 + POL-AC-001 POL-AM-001 §5 + POL-AC-001 §15	Security Officer	Quarterly	Yes	1
▶ CC2.1-03	CC2.1	Information is classified and handled according to its sensitivity, and classifications are recorded against the assets that hold it.	POL-DCL-001 POL-DCL-001 §5, §6	Security Officer	Annual	Yes	1
▶ CC2.1-04	CC2.1	Logging and monitoring produce records complete and reliable enough to base control and incident decisions on.	POL-LOG-001 POL-LOG-001 §6, §8	Security Officer	Continuous	Yes	1
▶ CC2.1-05	CC2.1	Security objectives are set annually with defined metrics, baselined and measured against actual performance.	POL-ISP-001 POL-ISP-001 §5	CEO	Annual	Yes	1

CONTROL ▲	CRITERION ▲	CONTROL ACTIVITY ▲	OWNING DOCUMENT AND SECTION ▲	OWNER ▲	FREQUENCY ▲	COVERED ▲	SCORE ▲
▼ CC2.2 4 covered · 2 to fix							
▶ CC2.2-01	CC2.2	Policies are published to the policy repository and personnel are notified on issue and on material change.	POL-ISP-001 POL-ISP-001 §6	Security Officer	On change	Yes	0
▶ CC2.2-02	CC2.2	Security responsibilities are communicated in writing and acknowledged as a condition of employment or engagement.	POL-COC-001 + POL-HRS-001 POL-COC-001 §17 + POL-HRS-001	Security Officer	On hire + annual	Yes	1
▶ CC2.2-03	CC2.2	Security awareness training is delivered at onboarding and annually, supported by periodic awareness communications.	POL-SAT-001 POL-SAT-001 §5, §11	Security Officer	On hire + annual	Yes	1
▶ CC2.2-04	CC2.2	Personnel report suspected security weaknesses and incidents through a published channel, and good-faith reporting is protected.	POL-IRP-001 + POL-COC-001 POL-IRP-001 §7 + POL-COC-001 §16	Security Officer	Continuous	Yes	1
▶ CC2.2-05	CC2.2	A written quarterly report goes to the Steering Committee covering control status, open deficiencies with owners and dates, and the security metrics.	POL-ISP-001 POL-ISP-001 §8	Security Officer	Quarterly	Partial	0
▶ CC2.2-06	CC2.2	Concerns about the conduct of the Security Officer, or which a person prefers not to raise with the Security Officer, may be reported directly to the CEO.	POL-ISP-001 + POL-COC-001 POL-ISP-001 §7 + POL-COC-001 §16	CEO	Continuous	No	0
▼ CC2.3 0 covered · 6 to fix							
▶ CC2.3-01	CC2.3	Security, availability and confidentiality commitments made to customers are recorded in the customer agreement or DPA, and reviewed annually against the controls actually in operation.	POL-ISP-001 + POL-VM-001 POL-ISP-001 §9 + POL-VM-001 §12	CEO	Annual	No	0

CONTROL ▲	CRITERION ▲	CONTROL ACTIVITY ▲	OWNING DOCUMENT AND SECTION ▲	OWNER ▲	FREQUENCY ▲	COVERED ▲	SCORE ▲
▶ CC2.3-02	CC2.3	A monitored security contact address is published externally so third parties can report vulnerabilities, and reports are triaged under the Incident Response Policy.	POL-ISP-001 + POL-IRP-001 POL-ISP-001 §9 + POL-IRP-001 §7	Security Officer	Continuous	Partial	1
▶ CC2.3-03	CC2.3	A current list of sub-processors and third parties that process customer data is maintained, and customers are notified of material changes.	POL-VM-001 + POL-PRIV-001 POL-VM-001 §12 + POL-PRIV-001 (not in the library)	Security Officer	On change	Partial	1
▶ CC2.3-04	CC2.3	Obligations to notify customers after a security incident, including triggers and timeframes, are defined and templated.	POL-IRP-001 + POL-PRIV-001 POL-IRP-001 §11 + POL-PRIV-001 §16 (not in the library)	CEO	On incident	Yes	1
▶ CC2.3-05	CC2.3	Security commitments to customers or prospective customers are reviewed by the Security Officer before they are made.	POL-ISP-001 POL-ISP-001 §9	Security Officer	Per commitment	No	0
▶ CC2.3-06	CC2.3	Vendors receive the Company's security requirements, and complementary user entity controls are communicated to customers.	POL-VM-001 POL-VM-001 §6, §12	Security Officer	On onboarding + annual	Partial	1
▼ CC3 · Risk Assessment 13 covered · 7 to fix							
▼ CC3.1 2 covered · 3 to fix							
▶ CC3.1-01	CC3.1	Security objectives are set annually, expressed in measurable terms, and approved by the Steering Committee.	POL-ISP-001 + POL-RSK-001 POL-ISP-001 §5 + POL-RSK-001 §5, §17	CEO	Annual	Yes	1
▶ CC3.1-02	CC3.1	The system boundary, service commitments and system requirements are defined and used as the stated scope of the risk assessment.	POL-ISP-001 + POL-RSK-001 POL-ISP-001 §8 + POL-RSK-001 §2	Security Officer	Annual	Partial	1
▶ CC3.1-03	CC3.1	Legal, regulatory and contractual security obligations are recorded in a single register and reviewed annually.	POL-ISP-001 + POL-COC-001 POL-ISP-001 §9 + POL-COC-001 §15 (no register owner named)	CEO	Annual	No	0

CONTROL ▲	CRITERION ▲	CONTROL ACTIVITY ▲	OWNING DOCUMENT AND SECTION ▲	OWNER ▲	FREQUENCY ▲	COVERED ▲	SCORE ▲
▶ CC3.1-04	CC3.1	A risk appetite statement defines which risks are accepted without treatment, which must be treated, and who may accept them.	POL-RSK-001 POL-RSK-001 §9, §16	CEO	Annual	Yes	1
▶ CC3.1-05	CC3.1	Each objective is linked to the controls that deliver it, so a control failure traces to the objective it puts at risk.	POL-ISP-001 POL-ISP-001 §8 → control matrix (link not yet required)	Security Officer	Annual	No	0
▼ CC3.2 7 covered · 0 to fix							
▶ CC3.2-01	CC3.2	A documented methodology defines the likelihood and impact scales, how they combine into a score, and the threshold at which a risk must be treated.	POL-RSK-001 POL-RSK-001 §7, §8, §9	Security Officer	Annual review	Yes	1
▶ CC3.2-02	CC3.2	A formal risk assessment is performed at least annually and repeated whenever a change trigger fires.	POL-RSK-001 POL-RSK-001 §5, §12	Security Officer	Annual + on trigger	Yes	1
▶ CC3.2-03	CC3.2	A risk register records each risk with an owner, an inherent score, the treatment decision, a residual score and a review date.	POL-RSK-001 POL-RSK-001 §10	Security Officer	Quarterly review	Yes	1
▶ CC3.2-04	CC3.2	Risk identification covers the entity itself, its vendors and sub-processors, and the AI models and agentic components in the service.	POL-RSK-001 POL-RSK-001 §6, §13, §14	Security Officer	Annual + on trigger	Yes	1
▶ CC3.2-05	CC3.2	Every risk above the treatment threshold has a treatment plan with a named owner and a target date, and progress is reported quarterly.	POL-RSK-001 POL-RSK-001 §9, §17	Security Officer	Quarterly	Yes	1
▶ CC3.2-06	CC3.2	Risk acceptances are approved by the CEO and recorded with the rationale, the decider, the date and an expiry.	POL-RSK-001 POL-RSK-001 §16	CEO	As they occur	Yes	1

CONTROL ▲	CRITERION ▲	CONTROL ACTIVITY ▲	OWNING DOCUMENT AND SECTION ▲	OWNER ▲	FREQUENCY ▲	COVERED ▲	SCORE ▲
▶ CC3.2-07	CC3.2	Vendors and sub-processors are risk-assessed before onboarding and reassessed annually where they process customer data.	POL-RSK-001 + POL-VM-001 POL-RSK-001 §13 + POL-VM-001 §5, §7	Security Officer	On onboarding + annual	Yes	1
▼ CC3.3 2 covered · 2 to fix							
▶ CC3.3-01	CC3.3	The annual risk assessment includes a fraud section covering fraudulent reporting, misappropriation of assets, corruption, and management override of controls.	POL-RSK-001 + POL-COC-001 POL-RSK-001 §11 + POL-COC-001 §5, §13	CEO	Annual	Yes	1
▶ CC3.3-02	CC3.3	Insider misuse of privileged access — including standing access held inside customer environments — is assessed explicitly as a fraud risk.	POL-RSK-001 + POL-AC-001 + POL-LOG-001 POL-RSK-001 §11 + POL-AC-001 §9, §14 + POL-LOG-001 §12	Security Officer	Annual	Yes	1
▶ CC3.3-03	CC3.3	The potential for management override of controls is assessed, and the compensating controls are documented given a single-member Steering Committee.	POL-RSK-001 + POL-ISP-001 + FRM-CE-001 POL-RSK-001 §11 + POL-ISP-001 §8 → FRM-CE-001	CEO	Annual	Yes	1
▶ CC3.3-04	CC3.3	Suspected fraud is handled under the conduct process, and a nil return is recorded annually where there has been none.	POL-RSK-001 + POL-COC-001 POL-RSK-001 §11, §18 + POL-COC-001 §16, §18	CEO	As they occur + annual	Partial	1
▼ CC3.4 2 covered · 2 to fix							
▶ CC3.4-01	CC3.4	A defined list states what obliges a risk reassessment: new product or model, new customer segment, new vendor or sub-processor, new jurisdiction, infrastructure change, material headcount change, regulatory change.	POL-RSK-001 POL-RSK-001 §12	Security Officer	Annual review of the list	Yes	1
▶ CC3.4-02	CC3.4	When a trigger fires the risk assessment is refreshed and the change is approved before it goes live.	POL-RSK-001 + POL-CM-001 POL-RSK-001 §12, §18 + POL-CM-001 §5, §12	Security Officer	On trigger	Yes	1

CONTROL ▲	CRITERION ▲	CONTROL ACTIVITY ▲	OWNING DOCUMENT AND SECTION ▲	OWNER ▲	FREQUENCY ▲	COVERED ▲	SCORE ▲
▶ CC3.4-03	CC3.4	Changes to the system boundary are reflected in the System Security Plan and the asset inventory.	POL-ISP-001 + POL-AM-001 + POL-RSK-001 POL-ISP-001 §8 + POL-AM-001 §5 + POL-RSK-001 §6	Security Officer	On change	Partial	1
▶ CC3.4-04	CC3.4	External change — the threat landscape, applicable regulation and AI-specific developments — is monitored and reviewed at least annually.	POL-RSK-001 + POL-VM-001 + POL-AI-001 POL-RSK-001 §6, §17 + POL-VM-001 §7 + POL-AI-001 §19	Security Officer	Annual + continuous	Partial	1
▼ CC4 · Monitoring Activities 9 covered · 4 to fix							
▼ CC4.1 7 covered · 0 to fix							
▶ CC4.1-01	CC4.1	A control self-assessment covering every in-scope control is performed at least annually, is not performed solely by the person who operates the control, and is reviewed and signed by the CEO.	POL-ISP-001 + POL-RSK-001 POL-ISP-001 §8 + POL-RSK-001 §17	Security Officer	Annual	Yes	1
▶ CC4.1-02	CC4.1	Quarterly access reviews are performed across the systems in the audit boundary, producing a complete population and a recorded decision per entitlement, reconciled against reviews due.	POL-AC-001 POL-AC-001 §12, §15	Security Officer	Quarterly	Yes	1
▶ CC4.1-03	CC4.1	Vulnerability scanning runs at least monthly on production infrastructure and continuously on code dependencies, supported by an annual penetration test, with remediation verified before closure.	POL-VPM-001 POL-VPM-001 §5, §13	Security Officer	Monthly + annual	Yes	1
▶ CC4.1-04	CC4.1	Alert dispositions are reviewed at least monthly for production, recording the date, reviewer, period covered and conclusion; logging and alerting coverage is reviewed at least annually and after material change.	POL-LOG-001 POL-LOG-001 §8, §12	Security Officer	Monthly + annual	Yes	1

CONTROL ▲	CRITERION ▲	CONTROL ACTIVITY ▲	OWNING DOCUMENT AND SECTION ▲	OWNER ▲	FREQUENCY ▲	COVERED ▲	SCORE ▲
▶ CC4.1-05	CC4.1	The change population is reviewed at least quarterly for changes lacking an approver, self-approved changes, direct production modifications and emergency change frequency, and the review is recorded.	POL-CM-001 POL-CM-001 §8, §12	Security Officer	Quarterly	Yes	1
▶ CC4.1-06	CC4.1	At least one continuity exercise a year uses a realistic scenario, and every test records the objective, the result, the recovery objectives actually achieved and the deficiencies found.	POL-BCP-001 POL-BCP-001 §13, §15	Security Officer	Annual	Yes	1
▶ CC4.1-07	CC4.1	Independent evaluations are obtained where contractually required, and subservice organisation assurance reports are reviewed annually with complementary user entity controls confirmed.	POL-ISP-001 + POL-RSK-001 POL-ISP-001 §8 + POL-RSK-001 §13	CEO	Annual	Yes	1
▼ CC4.2 2 covered · 4 to fix							
▶ CC4.2-01	CC4.2	Deficiencies are recorded with an owner, a severity and a remediation date, and tracked to closure.	POL-ISP-001 POL-ISP-001 §8	Security Officer	Continuous	Yes	1
▶ CC4.2-02	CC4.2	Deficiencies are reported in writing to the Steering Committee at least quarterly, with those open beyond their agreed date escalated in that report.	POL-ISP-001 + POL-VPM-001 + POL-CM-001 POL-ISP-001 §8 + POL-VPM-001 §13 + POL-CM-001 §12	Security Officer	Quarterly	Yes	1
▶ CC4.2-03	CC4.2	Deficiencies from every evaluation source — self-assessment, access review, scanning, penetration test, change review, continuity test, incident and vendor assessment — are consolidated in a single log.	POL-ISP-001 + POL-CM-001 + POL-BCP-001 POL-ISP-001 §8 (plan of action) · POL-CM-001 §12 (deficiency log) · POL-BCP-001 §13 (risk register)	Security Officer	Continuous	Partial	1
▶ CC4.2-04	CC4.2	Corrective action is verified as effective before a deficiency is closed, not merely reported as done.	POL-VPM-001 + POL-RSK-001 POL-VPM-001 §13 + POL-RSK-001 §9	Security Officer	Continuous	Partial	1

CONTROL ▲	CRITERION ▲	CONTROL ACTIVITY ▲	OWNING DOCUMENT AND SECTION ▲	OWNER ▲	FREQUENCY ▲	COVERED ▲	SCORE ▲
▶ CC4.2-05	CC4.2	Deficiency trends and repeat findings are evaluated, and a recurring deficiency is escalated rather than closed again.	POL-VPM-001 + POL-CM-001 POL-VPM-001 §13 + POL-CM-001 §12	Security Officer	Quarterly	Partial	1
▶ CC4.2-06	CC4.2	Failure to perform a scheduled evaluation on time is itself recorded as a deficiency and escalated.	POL-BCP-001 + POL-ISP-001 POL-BCP-001 §15 + POL-ISP-001 §8	Security Officer	Quarterly	Partial	1
▼ CC5 · Control Activities 10 covered · 2 to fix							
▼ CC5.1 3 covered · 1 to fix							
▶ CC5.1-01	CC5.1	Controls are selected to treat identified risks, and the mapping from risk to control is recorded so that every control can be traced to the risk it exists to address.	POL-RSK-001 + POL-ISP-001 POL-RSK-001 §5, §9 + POL-ISP-001 §6	Security Officer	Annual + on trigger	Yes	1
▶ CC5.1-02	CC5.1	Control selection considers the level at which a risk arises and combines preventive and detective activity rather than relying on one type.	POL-RSK-001 + POL-ISP-001 POL-RSK-001 §9 (treatment options) + POL-ISP-001 §6	Security Officer	Annual	Partial	1
▶ CC5.1-03	CC5.1	Controls are not adopted solely because a framework lists them, and a control that treats no identified risk is challenged rather than retained.	POL-RSK-001 POL-RSK-001 §5	Security Officer	Annual	Yes	1
▶ CC5.1-04	CC5.1	Every Trust Services Criterion in the declared scope has at least one owning document and a named control owner.	POL-ISP-001 POL-ISP-001 §6, §13 (Annex A)	Security Officer	Annual	Yes	1
▼ CC5.2 4 covered · 0 to fix							
▶ CC5.2-01	CC5.2	Production and non-production workloads are separated at the cloud account boundary, with permission sets granting only the entitlements a role requires in each.	POL-AC-001 + POL-NET-001 + POL-AM-001 POL-AC-001 §10 + POL-NET-001 §5 + POL-AM-001 §8	Security Officer	Continuous	Yes	1

CONTROL ▲	CRITERION ▲	CONTROL ACTIVITY ▲	OWNING DOCUMENT AND SECTION ▲	OWNER ▲	FREQUENCY ▲	COVERED ▲	SCORE ▲
▶ CC5.2-02	CC5.2	Segregation of duties is applied where practicable and, where the Company's size prevents it, compensating controls are documented rather than the requirement being dropped.	POL-AC-001 + POL-CM-001 + POL-ISP-001 POL-AC-001 §5 + POL-CM-001 §6 + POL-ISP-001 §7	Security Officer	Annual	Yes	1
▶ CC5.2-03	CC5.2	Infrastructure and network configuration are defined as code, held in version control and applied through the pipeline, with drift detected and remediated.	POL-NET-001 + POL-CM-001 POL-NET-001 §12 + POL-CM-001 §5, §8	Security Officer	Continuous	Yes	1
▶ CC5.2-04	CC5.2	Access to deploy changes to production is restricted, and security requirements are applied through the development lifecycle rather than added at release.	POL-CM-001 + POL-SDLC-001 POL-CM-001 §6 + POL-SDLC-001 §4, §5, §6	Security Officer	Continuous	Yes	1
▼ CC5.3 3 covered · 1 to fix							
▶ CC5.3-01	CC5.3	Policies are approved by the Steering Committee, reviewed at least annually, and communicated to personnel on hire and on material change.	POL-ISP-001 POL-ISP-001 §6	CEO	Annual	Yes	1
▶ CC5.3-02	CC5.3	Standards and procedures that implement the policies are maintained and kept current with the Company's technology and threat environment.	POL-ISP-001 + STD-CLD-001 + STD-CRY-001 + STD-EPT-001 + STD-LOG-001 POL-ISP-001 §6 + STD-CLD-001, STD-CRY-001, STD-EPT-001, STD-LOG-001	Security Officer	Annual	Yes	1
▶ CC5.3-03	CC5.3	Exceptions are requested in writing, approved before taking effect, documented, risk-assessed, time-bound and reviewed at least annually, and are recorded as accepted risks.	POL-ISP-001 + POL-RSK-001 POL-ISP-001 §11 + POL-RSK-001 §16	CEO	As they occur	Yes	1
▶ CC5.3-04	CC5.3	Control activities are performed by competent personnel with defined responsibility, within the defined frequency, and deviations are corrected.	POL-ISP-001 POL-ISP-001 §7, §8	Security Officer	Quarterly	Partial	1

CONTROL ▲	CRITERION ▲	CONTROL ACTIVITY ▲	OWNING DOCUMENT AND SECTION ▲	OWNER ▲	FREQUENCY ▲	COVERED ▲	SCORE ▲
▼ CC6 · Logical and Physical Access 31 covered · 1 to fix							
▼ CC6.1 5 covered · 0 to fix							
▶ CC6.1-01	CC6.1	A single identity provider is operated, applications authenticate through single sign-on wherever technically supported, and sessions terminate when the underlying identity is suspended.	POL-AC-001 + POL-PWD-001 POL-AC-001 §6 + POL-PWD-001 §5	Security Officer	Continuous	Yes	1
▶ CC6.1-02	CC6.1	Multi-factor authentication is enforced for every person on every in-scope system, SMS and voice are not accepted as factors, privileged users hold phishing-resistant authenticators, and every person enrolls at least two.	POL-PWD-001 + POL-AC-001 POL-PWD-001 §6, §7 + POL-AC-001 §6	Security Officer	Continuous	Yes	1
▶ CC6.1-03	CC6.1	Password requirements follow current national guidance — length and breach screening rather than composition and scheduled expiry — and a Company password manager is provided and required for any credential not held by the identity provider.	POL-PWD-001 + POL-AC-001 POL-PWD-001 §8, §9 + POL-AC-001 §6	Security Officer	Continuous	Yes	1
▶ CC6.1-04	CC6.1	Access is denied by default and granted on least privilege and need to know, to a named individual identity, for a stated business purpose, and is time-bound where the purpose is time-bound.	POL-AC-001 POL-AC-001 §5	Security Officer	Continuous	Yes	1
▶ CC6.1-05	CC6.1	Access to Company systems requires an enrolled device meeting the compliance baseline, regardless of network location, and a non-compliant device is blocked until remediated.	POL-AC-001 + POL-NET-001 + POL-AM-001 POL-AC-001 §13 + POL-NET-001 §9 + POL-AM-001 §6, §7	Security Officer	Continuous	Yes	1
▼ CC6.2 4 covered · 0 to fix							

CONTROL ▲	CRITERION ▲	CONTROL ACTIVITY ▲	OWNING DOCUMENT AND SECTION ▲	OWNER ▲	FREQUENCY ▲	COVERED ▲	SCORE ▲
▶ CC6.2-01	CC6.2	Access is requested and approved before it is granted, and the request record identifies the requester, the access sought, the business justification, the approver and the date.	POL-AC-001 POL-AC-001 §7, §15	Security Officer	Per request	Yes	1
▶ CC6.2-02	CC6.2	New personnel receive a defined baseline role, access is never granted by copying an existing user, and production, customer data, identity provider and security tooling access requires separate Security Officer approval.	POL-AC-001 POL-AC-001 §7	Security Officer	Per hire	Yes	1
▶ CC6.2-03	CC6.2	Access is revoked within one business day of termination and immediately on involuntary termination, with the identity provider account suspended first and the suspension timestamp retained.	POL-AC-001 POL-AC-001 §8, §14	Security Officer	Per leaver	Yes	1
▶ CC6.2-04	CC6.2	Contractor identities carry an engagement end date so access lapses automatically, and a complete joiner, mover and leaver population is producible from the human resources system for any period.	POL-AC-001 POL-AC-001 §8, §15	Security Officer	Continuous	Yes	1
▼ CC6.3 5 covered · 0 to fix							
▶ CC6.3-01	CC6.3	Quarterly access reviews cover the systems in the audit boundary, produce a complete population and a decision per entitlement, are reconciled to reviews due, and removals are evidenced as removed.	POL-AC-001 POL-AC-001 §12, §15	Security Officer	Quarterly	Yes	1
▶ CC6.3-02	CC6.3	Privileged access is granted only where the role requires it, is separate from the day-to-day account where the platform supports it, is minimised through just-in-time elevation that expires automatically, and is reviewed quarterly.	POL-AC-001 + POL-PWD-001 POL-AC-001 §9 + POL-PWD-001 §6	Security Officer	Quarterly	Yes	1

CONTROL ▲	CRITERION ▲	CONTROL ACTIVITY ▲	OWNING DOCUMENT AND SECTION ▲	OWNER ▲	FREQUENCY ▲	COVERED ▲	SCORE ▲
▶ CC6.3-03	CC6.3	Break-glass credentials are held in the password manager under hardware multi-factor authentication, their use raises an alert and requires a ticket within one business day, and they are tested annually and rotated after use or a departure.	POL-AC-001 + POL-PWD-001 POL-AC-001 §9, §10 + POL-PWD-001 §11	Security Officer	Annual + on use	Yes	1
▶ CC6.3-04	CC6.3	Non-human and agentic identities are inventoried with a named human owner, purpose, reachable scope and last review date, operate under dedicated least-privilege identities with no wildcard permissions, and require a human approval gate for irreversible actions.	POL-AC-001 + POL-PWD-001 POL-AC-001 §11 + POL-PWD-001 §12	Security Officer	Quarterly + annual	Yes	1
▶ CC6.3-05	CC6.3	Access to client systems is granted only under the engagement agreement, limited to the scope authorised in writing, recorded in the engagement file, and relinquished at engagement close with written confirmation retained.	POL-AC-001 + POL-NET-001 POL-AC-001 §14 + POL-NET-001 §13	Security Officer	Per engagement	Yes	1
▼ CC6.4 4 covered · 0 to fix							
▶ CC6.4-01	CC6.4	The Company operates no facility processing Company or client information, no facility is established without Steering Committee approval and a System Security Plan amendment, and a register of physical assets records custodian and classification.	POL-PHY-001 POL-PHY-001 §5	CEO	Annual	Yes	1
▶ CC6.4-02	CC6.4	Physical and environmental controls are carved out to AWS, whose assurance report is obtained at least annually, reviewed for exceptions and complementary user entity controls, with gaps recorded in the risk register.	POL-PHY-001 + POL-RSK-001 POL-PHY-001 §6 + POL-RSK-001 §13	Security Officer	Annual	Yes	1

CONTROL ▲	CRITERION ▲	CONTROL ACTIVITY ▲	OWNING DOCUMENT AND SECTION ▲	OWNER ▲	FREQUENCY ▲	COVERED ▲	SCORE ▲
▶ CC6.4-03	CC6.4	The remote work environment protects screens, printed material and conversations from observation, with automatic screen lock within fifteen minutes, a clear desk, devices never left unattended in vehicles, and no household access to screens, endpoints or records.	POL-PHY-001 + POL-DCL-001 POL-PHY-001 §7, §14 + POL-DCL-001 §8	Security Officer	Continuous + annual	Yes	1
▶ CC6.4-04	CC6.4	At client premises personnel comply with site rules, treat client badges and keys as Restricted and return them at engagement close with the return recorded, do not permit tailgating, and use physical access only within the scope authorised in writing.	POL-PHY-001 POL-PHY-001 §9	Security Officer	Per engagement	Yes	1
▼ CC6.5 3 covered · 0 to fix							
▶ CC6.5-01	CC6.5	Every device that has held Company or client information is sanitised before reassignment, return to a lessor, resale, donation or recycling, and a device that cannot be sanitised is physically destroyed rather than returned readable.	POL-DRD-001 + POL-PHY-001 + POL-AM-001 POL-DRD-001 §10, §11 + POL-PHY-001 §12 + POL-AM-001 §11	Security Officer	On disposal	Yes	1
▶ CC6.5-02	CC6.5	Disposal of Confidential or Restricted information is authorised by the Security Officer before it is carried out, occurs within thirty days of the retention period ending, is confirmed clear of legal hold, and Restricted disposal is verified by a second person or reviewed and signed by the CEO.	POL-DRD-001 POL-DRD-001 §9	Security Officer	On disposal	Yes	1
▶ CC6.5-03	CC6.5	A disposal register records each disposal action with its classification, retention basis and evidence, holds vendor certificates of destruction and provider deletion confirmations, is retained for six years, and is reconciled against the asset inventory.	POL-DRD-001 + POL-AM-001 POL-DRD-001 §15 + POL-AM-001 §11, §13	Security Officer	Continuous	Yes	1

CONTROL ▲	CRITERION ▲	CONTROL ACTIVITY ▲	OWNING DOCUMENT AND SECTION ▲	OWNER ▲	FREQUENCY ▲	COVERED ▲	SCORE ▲
▼ CC6.6 3 covered · 1 to fix							
▶ CC6.6-01	CC6.6	Network controls deny by default, workloads run in private subnets, administrative ports are not reachable from the internet, and public exposure of a data store raises an alert.	POL-NET-001 POL-NET-001 §5, §6	Security Officer	Continuous	Yes	1
▶ CC6.6-02	CC6.6	Internet-facing application endpoints sit behind a web application firewall with a maintained managed rule set deployed in monitoring mode before enforcement, with platform denial-of-service protection enabled.	POL-NET-001 POL-NET-001 §7	Security Officer	Continuous	Yes	1
▶ CC6.6-03	CC6.6	A current network diagram shows accounts, environments, public entry points and trust boundaries, and is maintained as the architecture changes.	POL-NET-001 POL-NET-001 §14 (listed as evidence only)	Security Officer	Annual + on change	No	0
▶ CC6.6-04	CC6.6	Administrative access to infrastructure is obtained through the identity provider and platform session brokering rather than by opening inbound network paths, and internet-exposed services are enumerated and reviewed at least quarterly against the asset inventory.	POL-NET-001 POL-NET-001 §7, §8, §14	Security Officer	Quarterly	Yes	1
▼ CC6.7 4 covered · 0 to fix							
▶ CC6.7-01	CC6.7	Information in transit is encrypted with TLS 1.2 as a minimum and 1.3 preferred, restricted to forward-secret authenticated cipher suites, with HTTP Strict Transport Security on public endpoints and no unencrypted alternative offered.	POL-ENC-001 + POL-DCL-001 POL-ENC-001 §6 + POL-DCL-001 §11	Security Officer	Continuous	Yes	1

CONTROL ▲	CRITERION ▲	CONTROL ACTIVITY ▲	OWNING DOCUMENT AND SECTION ▲	OWNER ▲	FREQUENCY ▲	COVERED ▲	SCORE ▲
▶ CC6.7-02	CC6.7	Confidential and Restricted information is encrypted at rest with AES-256 or equivalent, cloud storage, databases, backups and snapshots have encryption enabled by default at account level, customer-managed keys protect the sensitive stores, and keys are generated in and never leave a managed key service.	POL-ENC-001 + POL-DCL-001 POL-ENC-001 §7, §8 + POL-DCL-001 §11	Security Officer	Continuous	Yes	1
▶ CC6.7-03	CC6.7	Secrets are held in a managed secrets service or the password manager and retrieved at runtime, never appear in source, configuration, images, build logs, client deliverables or model context, and automated secret scanning runs on every repository with push protection.	POL-ENC-001 + POL-PWD-001 POL-ENC-001 §9 + POL-PWD-001 §12	Security Officer	Continuous	Yes	1
▶ CC6.7-04	CC6.7	Restricted information is not transmitted over unencrypted channels or held in personal accounts, cloud storage or AI tools, removable media is not used for it, and outbound traffic from production and from agentic systems is restricted to enumerated destinations.	POL-DCL-001 + POL-NET-001 + POL-AC-001 POL-DCL-001 §8, §11, §12 + POL-NET-001 §10 + POL-AC-001 §13	Security Officer	Continuous	Yes	1
▼ CC6.8 3 covered · 0 to fix							
▶ CC6.8-01	CC6.8	Endpoint detection and response software is deployed to every enrolled device with tamper protection enabled, and coverage is reconciled against device management, the identity provider and the personnel list at least quarterly.	POL-AM-001 POL-AM-001 §6, §13	Security Officer	Quarterly	Yes	1

CONTROL ▲	CRITERION ▲	CONTROL ACTIVITY ▲	OWNING DOCUMENT AND SECTION ▲	OWNER ▲	FREQUENCY ▲	COVERED ▲	SCORE ▲
▶ CC6.8-02	CC6.8	Software installation is restricted or subject to approval, administrative rights on endpoints are granted only where a role requires them, and only licensed, supported software is used with end-of-support software upgraded, replaced or removed.	POL-AM-001 POL-AM-001 §6, §9	Security Officer	Continuous	Yes	1
▶ CC6.8-03	CC6.8	Third-party application access to the identity provider and productivity suite is restricted by allow-list, and connected applications are reviewed at least quarterly with anything not on the inventory removed or brought through vendor management.	POL-AM-001 + POL-VM-001 POL-AM-001 §9 + POL-VM-001 §11	Security Officer	Quarterly	Yes	1
- CC7 · System Operations 19 covered · 2 to fix							
- CC7.1 4 covered · 0 to fix							
▶ CC7.1-01	CC7.1	Infrastructure and network configuration are evaluated continuously against a defined baseline, and drift is raised as a finding with an owner and a remediation date.	POL-NET-001 + STD-CLD-001 POL-NET-001 §6, §12 + STD-CLD-001	Security Officer	Continuous	Yes	1
▶ CC7.1-02	CC7.1	Automated vulnerability scanning runs at least monthly on production infrastructure and continuously on code dependencies, with cloud misconfiguration treated as a vulnerability.	POL-VPM-001 + POL-AM-001 POL-VPM-001 §5 + POL-AM-001 §6	Security Officer	Monthly + continuous	Yes	1
▶ CC7.1-03	CC7.1	Criticality is determined from technical severity adjusted for exploitability in the Company's actual environment and the harm that results, with chaining and lateral movement assessed and the rationale recorded.	POL-VPM-001 + POL-RSK-001 POL-VPM-001 §6, §8 + POL-RSK-001 §8	Security Officer	Per finding	Yes	1

CONTROL ▲	CRITERION ▲	CONTROL ACTIVITY ▲	OWNING DOCUMENT AND SECTION ▲	OWNER ▲	FREQUENCY ▲	COVERED ▲	SCORE ▲
▶ CC7.1-04	CC7.1	Agentic and model-specific weaknesses are assessed through evaluation and adversarial testing before release and on significant change, and over-broad agent permissions are treated as vulnerabilities with a remediation timeline.	POL-VPM-001 POL-VPM-001 §11	Security Officer	Per release + on change	Yes	1
▼ CC7.2 4 covered · 0 to fix							
▶ CC7.2-01	CC7.2	Security-relevant events are logged with sufficient detail to establish what occurred, when, where, the source and the identity involved, with synchronised clocks, and audit logging cannot be disabled or reduced outside change management.	POL-LOG-001 + STD-LOG-001 POL-LOG-001 §6 + STD-LOG-001	Security Officer	Continuous	Yes	1
▶ CC7.2-02	CC7.2	Logs are protected against unauthorised access, modification and deletion, retained for at least thirteen months with the most recent ninety days immediately queryable, and sensitive values are never written to logs.	POL-LOG-001 POL-LOG-001 §7	Security Officer	Continuous	Yes	1
▶ CC7.2-03	CC7.2	Automated alerts are configured for high-risk events, triaged promptly with suspected incidents escalated, and alerting coverage is reviewed at least annually and after material change with pipeline failures detected and remediated.	POL-LOG-001 POL-LOG-001 §8, §13	Security Officer	Continuous + annual	Yes	1
▶ CC7.2-04	CC7.2	Agent and model activity is logged with enough context to reconstruct behaviour — triggering input, tools invoked, parameters, actions taken and approvals at human gates — with alerting on behaviour outside expected bounds.	POL-LOG-001 POL-LOG-001 §10, §11	Security Officer	Continuous	Yes	1
▼ CC7.3 4 covered · 0 to fix							

CONTROL ▲	CRITERION ▲	CONTROL ACTIVITY ▲	OWNING DOCUMENT AND SECTION ▲	OWNER ▲	FREQUENCY ▲	COVERED ▲	SCORE ▲
▶ CC7.3-01	CC7.3	Each reported event is evaluated by the Security Officer, assigned a severity, declared an incident where warranted, and the decision and its reasoning are recorded.	POL-IRP-001 POL-IRP-001 §5, §8	Security Officer	Per event	Yes	1
▶ CC7.3-02	CC7.3	A four-level severity scale with defined triggers governs response, severity is reassessed as understanding improves, and is raised readily but lowered only with a recorded reason.	POL-IRP-001 POL-IRP-001 §5	Security Officer	Per incident	Yes	1
▶ CC7.3-03	CC7.3	A complete population of alerts raised in a period is retained together with the disposition of each, including those assessed as not requiring incident response.	POL-LOG-001 + POL-IRP-001 POL-LOG-001 §13 + POL-IRP-001 §8	Security Officer	Monthly	Yes	1
▶ CC7.3-04	CC7.3	Reports from clients, security researchers and the public through the published disclosure channel, and notifications that a vendor has suffered an incident, enter the same evaluation process as internally detected events.	POL-IRP-001 + POL-VM-001 POL-IRP-001 §7 + POL-VM-001 §7	Security Officer	Continuous	Yes	1
▼ CC7.4 4 covered · 1 to fix							
▶ CC7.4-01	CC7.4	Incident roles are assigned by name in advance — incident lead, Accountable Party, communications lead and scribe — with the incident lead and communications lead being different people at Severity Two and above.	POL-IRP-001 POL-IRP-001 §6	CEO	Annual	Partial	1
▶ CC7.4-02	CC7.4	Containment is proportionate, may be taken before root cause is established, and every containment action is recorded with its timestamp because those timestamps determine the exposure window.	POL-IRP-001 POL-IRP-001 §8	Security Officer	Per incident	Yes	1

CONTROL ▲	CRITERION ▲	CONTROL ACTIVITY ▲	OWNING DOCUMENT AND SECTION ▲	OWNER ▲	FREQUENCY ▲	COVERED ▲	SCORE ▲
▶ CC7.4-03	CC7.4	Evidence is captured before a compromised system is rebuilt, logs are preserved beyond their normal retention, handling is recorded, and agent action logs are preserved alongside conventional evidence.	POL-IRP-001 POL-IRP-001 §9	Security Officer	Per incident	Yes	1
▶ CC7.4-04	CC7.4	Notification obligations are extracted from customer agreements in advance with the shortest applicable period and its trigger recorded, the breach assessment is recorded including where notification is not required, and the decision to notify is approved by the Accountable Party.	POL-IRP-001 POL-IRP-001 §11	CEO	Per incident + annual	Yes	1
▶ CC7.4-05	CC7.4	Artificial intelligence and agentic events are named as incidents, the first containment action is to pause or disable the agent, activity is reconstructed from logs, and what reached a third-party provider is established.	POL-IRP-001 + POL-VPM-001 POL-IRP-001 §10 + POL-VPM-001 §11	Security Officer	Per incident	Yes	1
▼ CC7.5 3 covered · 1 to fix							
▶ CC7.5-01	CC7.5	Systems are restored to a known-good state, credentials rotated and the vector confirmed closed before an incident is closed, with enhanced monitoring applied to affected systems for a defined period afterwards.	POL-IRP-001 POL-IRP-001 §13	Security Officer	Per incident	Yes	1
▶ CC7.5-02	CC7.5	A post-incident review is held for every incident of Severity Two or above and for any incident that reached a client, within ten business days of closure, identifying root cause, what failed, what worked and corrective actions with owners and dates.	POL-IRP-001 POL-IRP-001 §13	Security Officer	Per incident	Yes	1

CONTROL ▲	CRITERION ▲	CONTROL ACTIVITY ▲	OWNING DOCUMENT AND SECTION ▲	OWNER ▲	FREQUENCY ▲	COVERED ▲	SCORE ▲
▶ CC7.5-03	CC7.5	Corrective actions from incidents are recorded in the single deficiency population, tracked to closure, and their completion reported to the Steering Committee.	POL-IRP-001 POL-IRP-001 §13 (deficiency log)	Security Officer	Per incident	Partial	1
▶ CC7.5-04	CC7.5	The incident response plan is exercised at least annually through a tabletop, the contact list, notification extract and escalation paths are verified current during the exercise, and the plan is reviewed annually and after any Severity One incident.	POL-IRP-001 + POL-SAT-001 POL-IRP-001 §14 + POL-SAT-001 §10	Security Officer	Annual	Yes	1
▼ CC8 · Change Management 7 covered · 0 to fix							
▼ CC8.1 7 covered · 0 to fix							
▶ CC8.1-01	CC8.1	Every change in scope is recorded in the change tracking system with a description, a business justification and an identified owner.	POL-CM-001 POL-CM-001 §5, §9	Security Officer	Per change	Yes	1
▶ CC8.1-02	CC8.1	Changes are assessed for security impact before approval, including effects on access controls, data protection, logging and customer commitments.	POL-CM-001 + POL-RSK-001 POL-CM-001 §5 + POL-RSK-001 §12	Security Officer	Per change	Yes	1
▶ CC8.1-03	CC8.1	Changes are approved before implementation by someone who is not the sole author, tested in a non-production environment where practicable, and carry a documented rollback plan.	POL-CM-001 POL-CM-001 §5, §6	Security Officer	Per change	Yes	1
▶ CC8.1-04	CC8.1	Production is reached only through the pipeline, branch protection requires a pull request with at least one approving review from a non-author and passing status checks, and direct modification of production raises an alert.	POL-CM-001 POL-CM-001 §10	Security Officer	Continuous	Yes	1

CONTROL ▲	CRITERION ▲	CONTROL ACTIVITY ▲	OWNING DOCUMENT AND SECTION ▲	OWNER ▲	FREQUENCY ▲	COVERED ▲	SCORE ▲
▶ CC8.1-05	CC8.1	Changes are categorised as standard, normal or emergency; the standard list is maintained and reviewed annually; emergency changes are retroactively approved within five business days and their frequency reviewed quarterly.	POL-CM-001 POL-CM-001 §7, §9	Security Officer	Per change + quarterly	Yes	1
▶ CC8.1-06	CC8.1	Changes to prompts, tool definitions, retrieval configuration, guardrails and model versions follow the same approval path as code, model versions are pinned, and an agent may not approve, merge or deploy a change to production.	POL-CM-001 + POL-LOG-001 POL-CM-001 §11 + POL-LOG-001 §11	Security Officer	Per change	Yes	1
▶ CC8.1-07	CC8.1	A complete population of production deployments for any period is exportable, each traceable to an approved change and to an approver other than the author.	POL-CM-001 POL-CM-001 §10, §12	Security Officer	Quarterly	Yes	1
▼ CC9 · Risk Mitigation 9 covered · 1 to fix							
▼ CC9.1 4 covered · 1 to fix							
▶ CC9.1-01	CC9.1	A business impact analysis identifies critical activities, the systems, data, personnel and third parties each depends on, assigns criticality ratings with the recovery objectives that follow, and is reviewed annually and on significant change.	POL-BCP-001 POL-BCP-001 §5, §6	Security Officer	Annual	Yes	1
▶ CC9.1-02	CC9.1	The continuity strategy holds no unique state outside recoverable systems: infrastructure is defined as code sufficient to rebuild in another Availability Zone or Region, and Critical workloads are deployed across at least two zones.	POL-BCP-001 POL-BCP-001 §7	Security Officer	Continuous	Yes	1

CONTROL ▲	CRITERION ▲	CONTROL ACTIVITY ▲	OWNING DOCUMENT AND SECTION ▲	OWNER ▲	FREQUENCY ▲	COVERED ▲	SCORE ▲
▶ CC9.1-03	CC9.1	Data is backed up on a schedule consistent with the recovery point objective, encrypted, replicated to a second Region, immutable for Critical data, and restoration is tested at least annually by restoring actual data and verifying its integrity.	POL-BCP-001 POL-BCP-001 §9	Security Officer	Annual + continuous	Yes	1
▶ CC9.1-04	CC9.1	Every critical responsibility has a documented procedure and a named alternate, and the Security Officer role has a designated alternate with equivalent access available through the break-glass procedure.	POL-BCP-001 + POL-RSK-001 POL-BCP-001 §8 + POL-RSK-001 §15	CEO	Annual	Partial	1
▶ CC9.1-05	CC9.1	A disruption likely to exceed a recovery objective is notified immediately, the CEO declares and the declaration is recorded, a contemporaneous log of actions and times is kept, security controls are not disabled during recovery, and stand-down confirms restoration.	POL-BCP-001 POL-BCP-001 §11	CEO	On invocation	Yes	1
▼ CC9.2 5 covered · 0 to fix							
▶ CC9.2-01	CC9.2	Vendors are tiered by criticality and data sensitivity, and the inventory records tier, data shared, owner and review date and is reviewed at least annually.	POL-VM-001 POL-VM-001 §5, §12	Security Officer	Annual	Yes	1
▶ CC9.2-02	CC9.2	Critical and High tier vendors are assessed before onboarding, Security Officer approval is required before Confidential or Restricted data is shared, and contracts carry confidentiality, data protection, breach notification, return or deletion and flow-down of customer requirements.	POL-VM-001 POL-VM-001 §6	Security Officer	Per vendor	Yes	1

CONTROL ▲	CRITERION ▲	CONTROL ACTIVITY ▲	OWNING DOCUMENT AND SECTION ▲	OWNER ▲	FREQUENCY ▲	COVERED ▲	SCORE ▲
▶ CC9.2-03	CC9.2	Attestations are reviewed rather than collected: a dated review records the period covered, the opinion, any exceptions, and identifies the complementary user entity controls the report places on the Company, each assigned an owner and confirmed as operating.	POL-VM-001 + POL-PHY-001 POL-VM-001 §7, §9 + POL-PHY-001 §6	Security Officer	Annual	Yes	1
▶ CC9.2-04	CC9.2	Model providers are assessed as vendors and usually sub-processors, establishing training use, retention, hosting and the contract tier actually purchased, with zero-retention or no-training configuration evidenced by both the organisation setting and the contractual clause.	POL-VM-001 + POL-AI-001 POL-VM-001 §10 + POL-AI-001 §11	Security Officer	Per provider + annual	Yes	1
▶ CC9.2-05	CC9.2	Vendor offboarding revokes access and returns or deletes data with confirmation obtained, and shadow vendors are detected through allow-listed application access, quarterly connected-application review and periodic expenditure reconciliation.	POL-VM-001 + POL-AM-001 POL-VM-001 §8, §11, §12 + POL-AM-001 §9	Security Officer	Per vendor + quarterly	Yes	1

A matrix view of the same data. Choose what the rows and columns are, and whether colour shows volume or gap share. Click any cell to list the controls inside it. The small grids below are fixed dashboard cuts that do not change with the selectors above.

What a score means

The tiles in the score grid below use these colours. The matrix above uses a separate red ramp for gap share — the two scales are different and are labelled separately.

0	Gap	Nothing in place. The control is neither written down nor operating. — 21 controls today
1	Documented	Written into an approved policy or procedure, but not yet operating in practice. Design only. — 137 controls today
2	Implemented	Operating in practice, but evidence is not consistently produced or retained. Sufficient for a Type I; will fail a Type II sample. — 1 control today
3	Evidenced	Operating with dated evidence retained for every occurrence, sufficient for an auditor to sample across the observation period. — 0 controls today
4	Automated	Evidence is produced and retained continuously by a system without manual effort, and drift is detected without anyone checking. — 0 controls today
N/A	Not applicable	The control does not apply at this company size. Excluded from both the score and the maximum so it does not distort readiness. The reason is recorded in the Governance Log. — 1 control today

Reading it: 1 is design only — the words exist, nothing has run. 2 means it runs but leaves no reliable trail, which passes a Type I and fails a Type II sample. 3 is the bar a Type II report is written against. N/A is excluded from both the score and the maximum so it cannot flatter readiness, and the reason is recorded in the Governance Log.

		POL-ISP-001	POL-RSK-001	POL-AC-001	POL-IRP-001	POL-CM-001	POL-COC-001	POL-VM-001	POL-AM-001	POL-HRS-001	POL-NET-001	POL-LOG-001	POL-BCP-001	POL-VPM-001	POL-PWD-001	POL-PHY-001	POL-DCL-001	FRM-CE-001	POL-DRD-001	POL-ENC-001	POL-SAT-001	POL-AI-001	POL-PRIV-001	STD-CLD-001	STD-EPT-001	STD-LOG-001	STD-SCR-001	POL-COI-001	POL-SDLC-001	STD-CRY-001	
2 - Communication and Information	CC1 - Control Environment	13	2	1			8	1		10							3			1				1		2	1			43 (34)	
	CC2 - Risk Assessment	8		1	3		3	3	1	1		1				1				1		2								25 (14)	
	CC3 - Risk Assessment	6	18	1		1	3	2	1			1					1				1									35 (16)	
	CC4 - Monitoring Activities	6	3	1		4					1	3	4																	22 (9)	
	CC5 - Control Activities	8	4	2		3			1		2												1	1	1			1	1	25 (3)	
	CC6 - Logical and Physical Access		1	15				1	6		7				7	5	4		3	3											52 (1)
	CC7 - System Operations		1		13			1	1		1	5		4							1			1		1					29 (2)
	CC8 - Change Management		1			7						1																			9
	CC9 - Risk Mitigation		1					5	1				5			1						1									14 (2)

Reading this grid

Rows are **Criterion group**, columns are **Owning document (all mentions)**. Each number is how many controls fall in that cell. Colour is the share of them that are a gap — darker red is worse.

Click a cell to list its controls. The right-hand figure on each row is the row total, with gaps in red.

Hottest cells

- 10 of 13 · CC1 × POL-ISP-001
- 7 of 8 · CC1 × POL-COC-001
- 7 of 10 · CC1 × POL-HRS-001
- 6 of 8 · CC2 × POL-ISP-001
- 5 of 6 · CC3 × POL-ISP-001
- 5 of 18 · CC3 × POL-RSK-001
- 3 of 3 · CC1 × FRM-CE-001
- 3 of 3 · CC2 × POL-VM-001

Matrix colour — gap share: No gaps up to 25% 25–50% 50–75% 75–99% all gaps Numbers are controls; the figure in the right margin is the row total with gaps in red

Control and subcontrol score grid

Every subcontrol as a tile, coloured by its score and grouped under its control. Hover a tile for the control activity and what the score means. Click a criterion group heading to collapse it.

Tile colour — score: 0 Gap 1 Documented 2 Implemented 3 Evidenced 4 Automated N/A Not applicable

CC1 · Control Environment28 subcontrols ·0x131x132x1N/Ax1

CC1.1

010203040506

6

CC1.2

010203040506

6

CC1.3

0102030405

5

CC1.4

010203040506

6

CC1.5

0102030405

5

CC2 · Communication and Information17 subcontrols ·0x51x12

CC2.1

0102030405

5

CC2.2

010203040506

6

CC2.3

010203040506

6

file:///Users/psharma/Downloads/control-policy-map-with-pdf-export.html

29/33

▾

CC3 · Risk Assessment

20 subcontrols ·

0x2

1x18

CC3.1

- 01
- 02
- 03
- 04
- 05

5

CC3.2

- 01
- 02
- 03
- 04
- 05
- 06
- 07

7

CC3.3

- 01
- 02
- 03
- 04

4

CC3.4

- 01
- 02
- 03
- 04

4

▾

CC4 · Monitoring Activities

13 subcontrols ·

1x13

CC4.1

- 01
- 02
- 03
- 04
- 05
- 06
- 07

7

CC4.2

- 01
- 02
- 03
- 04
- 05
- 06

6

▾

CC5 · Control Activities

12 subcontrols ·

1x12

CC5.1

- 01
- 02
- 03
- 04

4

CC5.2

- 01
- 02
- 03
- 04

4

CC5.3

- 01
- 02
- 03
- 04

4

▾

CC6 · Logical and Physical Access

32 subcontrols ·

0x1

1x31

CC6.1

- 01
- 02
- 03
- 04
- 05

5

CC6.2

- 01
- 02
- 03
- 04

4

CC6.3

- 01
- 02
- 03
- 04
- 05

5

CC6.4

- 01
- 02
- 03
- 04

4

CC6.5

- 01
- 02
- 03

3

CC6.6

- 01
- 02
- 03
- 04

4

CC6.7

- 01
- 02
- 03
- 04

4

CC6.8

- 01
- 02
- 03

3

▾

CC7 · System Operations

21 subcontrols ·

1x21

CC7.1

- 01
- 02
- 03
- 04

4

CC7.2

- 01
- 02
- 03
- 04

4

CC7.3

- 01
- 02
- 03
- 04

4

CC7.4

- 01
- 02
- 03
- 04
- 05

5

CC7.5

- 01
- 02
- 03
- 04

4

CC8 · Change Management 7 subcontrols · 1x7

CC8.1

- 01
- 02
- 03
- 04
- 05
- 06
- 07

7

CC9 · Risk Mitigation 10 subcontrols · 1x10

CC9.1

- 01
- 02
- 03
- 04
- 05

5

CC9.2

- 01
- 02
- 03
- 04
- 05

5

Criterion x cadence

How often the work in each criterion has to run

Criterion x operating mode

Where manual effort is concentrated

	Continuous	Monthly	Quarterly	Annual	Event-driven	
CC1	2		2	17	7	28
CC2	4		2	7	4	17
CC3	1		2	14	3	20
CC4	3	2	5	3		13
CC5	3		1	7	1	12
CC6	15		6	4	7	32
CC7	7	1		3	10	21
CC8	1		2		4	7
CC9	2		1	5	2	10

	Automated	Semi-automat.	Manual	
CC1	20	2	6	28
CC2	12	2	3	17
CC3	11	2	7	20
CC4	9		4	13
CC5	10		2	12
CC6	25		7	32
CC7	15	5	1	21
CC8	7			7
CC9	6		4	10

Criterion x score

Maturity spread; red where a cell holds gaps

	0	1	2	3	4	N/A	
CC1	13	13	1			1	28
CC2	5	12					17
CC3	2	18					20
CC4		13					13
CC5		12					12
CC6	1	31					32
CC7		21					21
CC8		7					7
CC9		10					10

Owner x criterion

Who carries which criterion

	CC1	CC2	CC3	CC4	CC5	CC6	CC7	CC8	CC9	
CEO	15	4	7	1	2	1	2		2	34
Security Officer	13	13	13	12	10	31	19	7	8	126